

Exército Brasileiro
Comando de Comunicações e Guerra Eletrônica do Exército



Escola de Comunicações
(Escola Coronel Hygino Corsetti)



Ethical Hacker



Networking
Academy



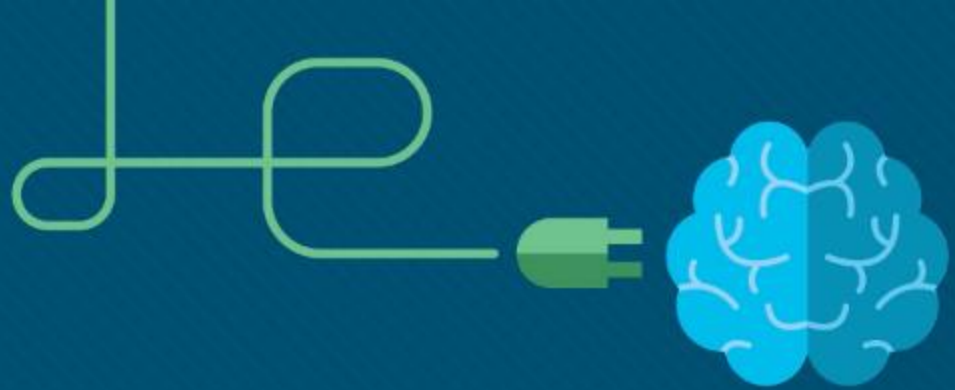
Programa
CiberEducação
Cisco Brasil



>_ WHOAMI

- Formação Acadêmica:
 - Mestrado em Engenharia Elétrica (Unb, 2026) – Áreas: Segurança Cibernética; Autenticação segura, certificados digitais, HPC.
 - Pós-graduação: Segurança da Informação (2022); Engenharia de Redes e Telecomunicações (2021).
 - Nível Superior: Análise e Desenvolvimento de Sistemas (2019).
- Formação Técnica e Certificações:
 - Ethical Hacker (Cisco netacademy)
 - Cyber Threat Management (Cisco netacademy)
 - CCNA Security
 - Curso de Guerra Cibernética (CIGE)
 - Estágio de Proteção Cibernética (EsCom)
- Atuação em Pesquisa:
 - Pesquisador DTI BR - Programa BLIS (2026-Atual): IA, Engenharia de prompts, RAG, segurança de LLM, Sistemas multiagentes.
 - Pesquisador da Escola Superior de Defesa (ESD): Geopolítica e computação de alta performance falando sobre soberania digital; e Estudo independente de criptografia PQC (Pós-Quântica).





Módulo 1: Introdução ao Hacking Ético e Testes de Penetração

Hacker Ético



Objetivos do Módulo

Título do módulo: Introdução a hacking ético e testes de penetração

Objetivo do módulo: Explique a importância de hacking ético metodológico e testes de penetração.

Título do tópico	Objetivo do Tópico
Entendendo hacking ético e teste de penetração	Explique a importância do hacking ético e teste de penetração.
Explorando metodologias de teste de penetração	Explique diferentes tipos de metodologias e frameworks de teste de penetração.
Construção do seu próprio laboratório	Configure uma máquina virtual para sua experiência de aprendizagem de teste de penetração.

1.1 Entendendo hacking ético e teste de penetração

Visão geral

- **Hacker** ético: uma pessoa que atua como atacante e avalia a postura de segurança da infraestrutura de uma rede ou do sistema para identificar e possivelmente explorar quaisquer fraquezas de segurança encontradas e, em seguida, determinar se um compromisso é possível.
- Este processo é chamado *de teste de penetração de segurança* ou *hacking ético*.
- O fator-chave para definir hackers éticos versus não éticos é que este último envolve intenção maliciosa.
- A permissão para ataque é frequentemente referida como "o escopo" do teste (o que você tem permissão ou não permissão para testar) e é crucial para tirá-lo de apuros!
- Um pesquisador de segurança que procura vulnerabilidades em produtos, aplicativos ou serviços Web é considerado um hacker ético se revelar com responsabilidade essas vulnerabilidades aos fornecedores ou proprietários da pesquisa direcionada.
- O mesmo tipo de "pesquisa" realizada por alguém que então usa a mesma **vulnerabilidade** para obter acesso não autorizado a uma rede/sistema de destino seria considerado um hacker não ético.
- Alguém que encontra uma vulnerabilidade e a revela publicamente sem trabalhar com um provedor é considerado um hacker não ético.
- Um hacker ético usa as mesmas ferramentas para encontrar vulnerabilidades e explorar alvos, assim como hackers não éticos.
- Um hacker ético geralmente relata as descobertas para o provedor ou cliente que ele ou ela está ajudando a tornar a rede mais segura, tentando evitar a realização de quaisquer testes ou explorações que possam ser destrutivos por natureza.

Por que precisamos fazer testes de penetração?

- Alguém que é responsável pela segurança e pela defesa de uma rede/sistema quer encontrar qualquer caminho possível de comprometimento antes dos atacantes.
- Ao longo dos anos, foram desenvolvidos e implementados vários tipos de técnicas defensivas diferentes, tais como antivírus, firewalls, sistemas de prevenção de intrusão [IPSs], e anti-malware.
- Como sabemos se essas defesas realmente funcionam e se são suficientes para manter fora os invasores?
- Quão valiosos são os dados que estamos protegendo, e estamos protegendo as coisas certas?
- Estas são algumas das perguntas que devem ser respondidas por um teste de penetração.
- Precisamos determinar o que estamos protegendo e se nossas defesas podem segurar as ameaças que são impostas a elas.
- Simplesmente implementar um firewall, um IPS, anti-malware, uma VPN, um firewall de aplicativo web (WAF) e outras defesas de segurança modernas não é suficiente.
- Você também precisa testar sua validade.
- E você precisa fazer isso regularmente porque as redes e os sistemas mudam constantemente.
- A superfície de ataque também pode mudar , e quando isso acontece, você precisa considerar reavaliar a postura de segurança por meio de um teste de penetração.

Atores de Ameaça

Veja a seguir os tipos mais comuns de atores de ameaça (atacantes mal-intencionados) **que vemos hoje:**

Tipos de atacantes mal-intencionados	Descrição
Crime organizado	O crime organizado vai para onde está o dinheiro.Ela consiste em grupos muito bem financiados e motivados que normalmente usarão qualquer uma das técnicas de ataque mais recentes.Se esse for um ransomware ou roubo de dados, se puder ser monetizado, o crime organizado o usará.
Hacktivistas	Hacktivistas não são motivados por dinheiro.Eles estão procurando fazer uma declaração ou promover suas crenças, usando crimes cibernéticos como seu método de ataque.Esses tipos de ataques são frequentemente realizados roubando dados confidenciais e, em seguida, revelando-os ao público com o propósito de embaraçar ou afetar financeiramente um alvo.
Atacantes patrocinados pelo Estado	Guerra cibernética e espionagem cibernética são dois termos que se enquadram nessa categoria.Muitos governos em todo o mundo hoje usam ataques cibernéticos para roubar informações de seus oponentes e causar interrupções.
Ameaças Internas	Ameaças internas vêm de dentro de uma organização.Eles são geralmente funcionários normais que são enganados para divulgar informações confidenciais ou clicar acidentalmente em links que permitem que os agressores obtenham acesso a seus computadores.No entanto, eles também podem ser insiders maliciosos que possivelmente são motivados por vingança ou dinheiro.

1.2 Explorando metodologias de teste de penetração

Visão geral

- Há mais nos testes de penetração do que apenas invadir a rede de um cliente.
- É importante seguir métodos e padrões conhecidos para abordar os compromissos de pentesting de forma organizada e sistemática.
- Você deve entender as principais metodologias e padrões documentados para poder criar estratégias que se baseem em seus pontos fortes.
- Documentar sua abordagem com as metodologias e padrões utilizados também proporciona prestação de contas (RELATÓRIO) para a nossa empresa e ajuda a tornar nossos resultados defensáveis caso ocorram problemas com nossos clientes.
- O processo de completar um teste de penetração varia de acordo com muitos fatores.
- As ferramentas e técnicas usadas para avaliar a postura de segurança de uma rede ou sistema também variam.
- As redes e os sistemas que estão sendo avaliados são, muitas vezes, altamente complexos.
- Por isso, é muito fácil quando se realiza um teste de penetração acabar saindo do escopo.
- É aí que entram as metodologias de teste.

Por que precisamos seguir uma metodologia de teste de penetração?

- Conforme mencionado anteriormente, o aumento de escopo é uma razão para a utilização de uma metodologia específica; no entanto, há muitas outras razões.
- Por exemplo, ao realizar um teste de penetração para um cliente, você deve mostrar que os métodos que você planeja usar para o teste são testados e comprovados.
- Utilizando uma metodologia conhecida, é possível fornecer documentação de um procedimento especializado usado por muitas pessoas.

Considerações Ambientais

- Vários tipos diferentes de testes de penetração são frequentemente combinados no escopo geral de um teste de penetração, mas eles também podem ser realizados como testes individuais.
- Uma lista de algumas das considerações ambientais mais comuns para os tipos de testes de penetração hoje é:

Considerações Ambientais	Descrição
Testes de infraestrutura de rede	Esses testes podem significar algumas coisas. Este curso tem o foco na avaliação da postura de segurança da infraestrutura de rede real e em como ela é capaz de ajudar na defesa contra ataques. Isso geralmente inclui os comutadores, roteadores, firewalls e recursos de suporte, como servidores AAA e IPSs. Um teste de penetração na infraestrutura sem fio pode, às vezes, ser incluído no escopo de um teste de infraestrutura de rede.
Testes baseados em aplicação	Foca no teste de fraquezas de segurança em aplicações corporativas. Essas fraquezas podem incluir, mas não se limitam a falhas de configurações, questões de validação de entrada, problemas de injeção e falhas lógicas. Como uma aplicação web é normalmente criada em um servidor web com um banco de dados de back-end, o objetivo de teste normalmente inclui também o banco de dados. No entanto, focaliza em obter acesso a esse banco de dados de suporte através do comprometimento da aplicação web.
Testes de penetração na nuvem	A responsabilidade pela segurança de nuvem depende do tipo de modelo em nuvem (SaaS, PaaS ou IaaS). Independentemente do modelo usado, a segurança em nuvem é de responsabilidade tanto do cliente quanto do provedor de nuvem. Esses detalhes precisam ser definidos antes de um contrato de computação em nuvem ser assinado. Esses contratos variam de acordo com os requisitos de segurança do cliente. As considerações incluem recuperação de desastre, SLAs, integridade de dados e criptografia.

Considerações Ambientais (Cont.)

- Muitos pentesters acham que o aspecto físico dos testes é o mais divertido porque eles estão essencialmente sendo pagos para invadir a instalação de um alvo.
- Este tipo de teste pode ajudar a expor quaisquer fraquezas no perímetro físico, bem como quaisquer mecanismos de segurança que estejam em vigor, como guardas, portões e cercas.
- O resultado deve ser uma avaliação dos controles de segurança física externos.
- A maioria dos comprometimentos hoje começam com algum tipo de ataque de engenharia social, como um telefonema, um e-mail, um site, uma mensagem SMS e assim por diante.
- É importante testar como seus funcionários lidam com esses tipos de situações.
- Este tipo de teste é muitas vezes omitido do escopo de um teste de penetração principalmente porque envolve testar pessoas em vez da tecnologia.
- Na maioria dos casos, a administração não concorda com esse tipo de abordagem, mas é importante ter uma visão real dos métodos de ataque mais recentes.
- O resultado de um teste de engenharia social deve ser avaliar o programa de conscientização sobre segurança para que você possa melhorá-lo.
- Não deve ser para identificar indivíduos que falham no teste.
- Uma ótima ferramenta para realizar campanhas de teste de engenharia social é o Social-Engineer Toolkit (SET), criado por Dave Kennedy.

Considerações ambientais (Cont.)

Os termos abaixo são usados para descrever a perspectiva a partir da qual o teste é realizado:

Método de teste de penetração	Descrição
Teste de ambiente desconhecido (anteriormente conhecido como <i>caixa-preta</i>)	O testador normalmente recebe apenas uma quantidade muito limitada de informações. Por exemplo, o testador pode receber apenas os nomes de domínio e endereços IP que estão no escopo de um alvo específico. A ideia desse tipo de limitação é fazer com que o testador comece com a perspectiva de que um atacante externo pode ter. Normalmente, um agressor determinaria um alvo e começaria a reunir informações sobre o alvo, usando informações públicas, e obteria mais e mais informações para usar nos ataques. O testador não teria conhecimento prévio da organização e da infraestrutura do alvo.
Teste de Ambiente Conhecido (anteriormente conhecido como <i>caixa-branca</i>)	O testador começa com uma quantidade significativa de informações sobre a organização e sua infraestrutura. O testador normalmente seriam fornecidos itens como diagramas de rede, endereços IP, configurações e um conjunto de credenciais de usuário. Se o escopo incluir uma avaliação do aplicativo, o testador também poderá receber o código-fonte do aplicativo de destino. A ideia desse tipo de teste é identificar o maior número possível de furos de segurança.
Teste de ambiente parcialmente conhecido (anteriormente conhecida como <i>caixa cinza</i>)	É um pouco de uma abordagem híbrida entre testes de ambiente desconhecido e conhecido. Com testes de ambiente parcialmente conhecidos, os testadores podem receber credenciais, mas não documentação completa da infraestrutura de rede. Isso permitiria que os testadores ainda fornecessem resultados de seus testes da perspectiva de um atacante externo.

Levantamento de diferentes padrões e metodologias

- Há várias metodologias de teste de penetração que existem há algum tempo e continuam a ser atualizadas à medida que novas ameaças emergem.
- A seguir está uma lista de algumas das metodologias de teste de penetração mais comuns e outros padrões:

MITRE ATT&CK	Um recurso incrível para aprender sobre táticas, técnicas e procedimentos de um adversário (TTPs). Tanto profissionais de segurança ofensivos (testadores de penetração, equipes vermelhas, caçadores de bugs, etc.) quanto respondentes de incidentes e equipes de busca de ameaças usam esta estrutura hoje. É um conjunto de diferentes matrizes de táticas, técnicas e sub-técnicas. Essas matrizes – incluindo a Matriz ATT&CK para Empresas, Rede, Nuvem, ICS e Móvel – listam as táticas e técnicas que os adversários usam enquanto se preparam para um ataque, incluindo o levantamento de informações (OSINT (inteligência de código aberto), identificação de fraquezas técnicas e humanas, e muito mais), bem como técnicas de exploração e pós-exploração diferentes.
Guia de testes de Security da Web OWASP (WSTG)	Um guia abrangente focado em testes de aplicativos Web. É uma compilação de muitos anos de trabalho dos membros do OWASP. Ele abrange as fases de alto nível de testes de segurança de aplicativos Web e se aprofunda nos métodos de teste usados. Por exemplo, vai até o ponto em que fornecer vetores de ataque para testar scripts entre sites (XSS), ataques de entidade externa XML (XXE), falsificação de solicitação entre sites (CSRF) e ataques de injeção de SQL; bem como prevenir e mitigar esses ataques. Ele é o guia mais detalhado e abrangente disponível.
NIST SP 800-115	Um documento criado pelo Instituto Nacional de Padrões e Tecnologia (NIST), que faz parte do Departamento de Comércio dos EUA. Fornece às organizações diretrizes sobre planejamento e realização de testes de segurança da informação. Ele substituiu o documento padrão anterior, SP 800-42. É considerado um padrão da indústria para orientação de testes de penetração e é mencionado em muitos outros padrões e documentos da indústria.

Levantamento de diferentes padrões e metodologias (cont.)

OSSTMM	O Manual de metodologia de teste de Security de código aberto (OSSTMM) existe há muito tempo. Distribuído pelo Instituto de Security e Metodologias Abertas (ISECOM), é um documento que apresenta testes de Security repetíveis e consistentes. Ele está atualmente na versão 3, e a versão 4 está em fase de rascunho. O OSSTMM tem as seguintes seções-chave: Métricas de Security operacionais, Análise de confiança, Fluxo de trabalho, Teste de Security humana, Testes de Security física, Testes de Security sem fio, Testes de Security de telecomunicações, Teste de Security de redes de dados, Regulamentações de conformidade e Relatório com o Relatório de auditoria de teste de Security (STAR).
PTES	O Padrão de Execução de Teste de Penetração (PTES) fornece informações sobre tipos de ataques e métodos, e fornece informações sobre as ferramentas mais recentes disponíveis para realizar os métodos de teste descritos. O PTES envolve sete fases distintas: Interações pré-engagement, Coleta de inteligência, Modelagem de ameaça, Análise de vulnerabilidade, Exploração, Pós-exploração e Relatórios.
ISSAF	A Estrutura de Avaliação de Security de Sistemas de Informação (ISSAF) é outra metodologia de teste de penetração, como as outras da lista, com algumas fases adicionais. Ela abrange as seguintes fases: Coleta de informações, Mapeamento de rede, Identificação de vulnerabilidade, Penetração, Obtenção de acesso e escalada de privilégios, Enumerando ainda mais, Comprometendo usuários/sites remotos, Mantendo acesso e Cobrindo os rastros.

1.3 Construindo seu próprio laboratório

Visão geral

- É importante que você desenvolva suas habilidades.
- As habilidades vêm com a prática, mas como você pode praticar se você não tem algo em que praticar?
- Não é possível praticar em redes e aplicativos dos clientes.
- Você pode praticar em alvos simulados, redes que você tem permissão para acessar e determinados sites na Internet aberta.
- Lembre-se! Algumas ferramentas e técnicas que são usadas em hacking ético podem ser vistas como ilegais.
- Além disso, a definição do que é legal ou ilegal pode diferir de um lugar para outro.
- Antes de usar ferramentas de hacking ético em qualquer rede ou aplicativo, considere cuidadosamente a legalidade do que você está planejando fazer.
- Quando em dúvida, pesquise a lei e peça conselhos aos outros.
- Neste tópico, você instalará e explorará uma máquina virtual Kali Linux (VM) cheia de ferramentas populares de hacking ético.
- A VM também inclui redes IP internas simuladas que incluem uma variedade de sistemas intencionalmente vulneráveis.

Visão geral (Cont.)

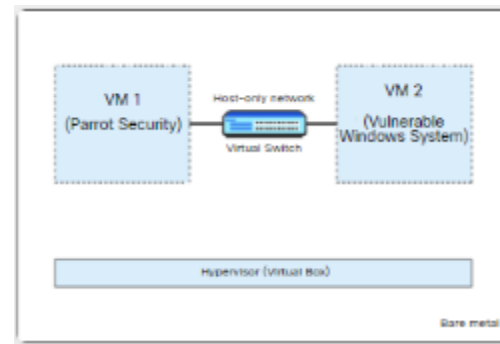
- Quando se trata de testes de penetração, um ambiente de laboratório adequado é muito importante.
- A aparência desse ambiente depende do tipo de teste que você está fazendo.
- Os tipos de ferramentas usadas em um laboratório também variam de acordo com diferentes fatores.
- Se você está executando testes de penetração em uma rede de clientes, sua própria rede ou um dispositivo específico, você sempre precisa de algum tipo de ambiente de laboratório para usar para testes.
- Por exemplo, ao testar uma rede de clientes, você provavelmente estará fazendo a maioria dos seus testes em relação aos ambientes de produção ou preparação do cliente, pois estes são os ambientes que um cliente geralmente está preocupado em proteger corretamente.
- Como esse pode ser um ambiente de rede crítico, você deve ter certeza de que suas ferramentas foram testadas e comprovadas – e é aí que entra o ambiente de teste do laboratório.

Visão geral (Cont.)

- Você deve sempre testar suas ferramentas e técnicas em seu ambiente de laboratório antes de executá-las na rede do cliente.
- Não há garantias de que as ferramentas que você usa não quebrarão nada.
- Na verdade, muitas ferramentas são projetadas para quebrar coisas.
- Portanto, você precisa saber o que esperar antes de liberar ferramentas em uma rede do cliente.
- Ao testar um dispositivo ou solução específico que esteja somente em um ambiente de laboratório, há menos preocupação em quebrar coisas.
- Com este tipo de teste, você normalmente utiliza uma rede fechada que pode ser facilmente revertida, se necessário.

Visão geral (Cont.)

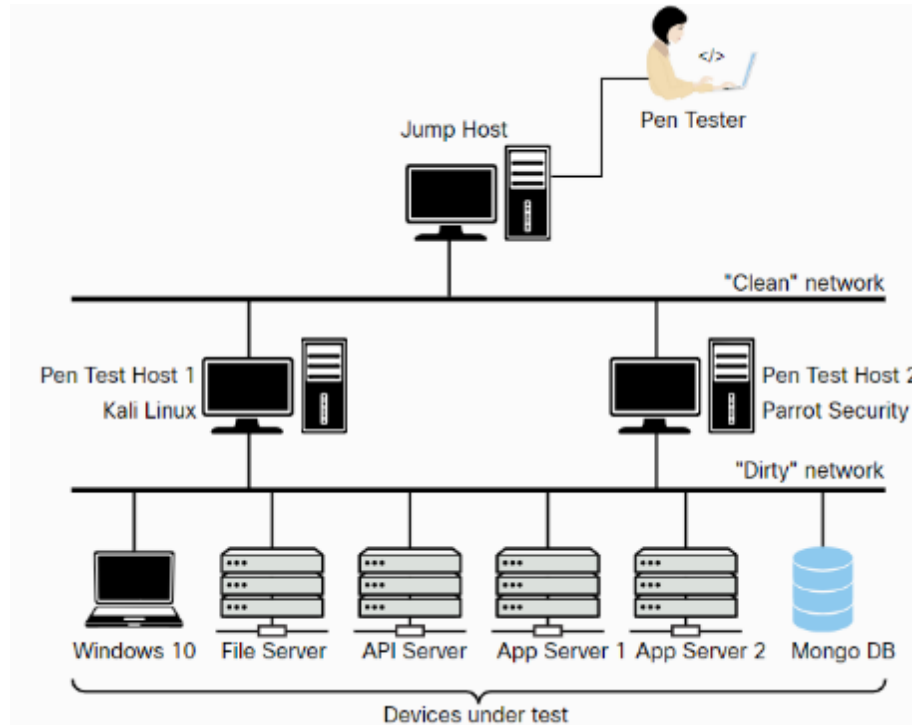
- Existem muitas distribuições diferentes do Linux que incluem ferramentas de teste de penetração e recursos, como Kali Linux (kali.org), Parrot OS (parrotsec.org) e BlackArch (blackarch.org).
- Essas distribuições Linux fornecem a você um ambiente muito conveniente para começar a aprender sobre as diferentes ferramentas de segurança e metodologias usadas em testes de penetração.
- É possível implementar um laboratório de teste de penetração básica usando apenas algumas VMs em ambientes de virtualização, como a Virtual Box (virtualbox.org) ou a Workstation/Fusão VMware (vmware.com).
- A figura mostra duas VMs (uma executando o Parrot OS e outra executando um sistema vulnerável do Microsoft Windows).
- As duas VMs estão conectadas por meio de uma configuração de comutador virtual e de uma "rede somente host".
- Este tipo de configuração permite executar diferentes ataques e enviar pacotes IP entre VMs sem esses pacotes deixando o sistema físico (bare-metal).



Construindo seu próprio laboratório

Visão geral (Cont.)

- A Figura 1-2 mostra uma topologia mais elaborada para um ambiente de laboratório de teste de penetração.



Requisitos e diretrizes para laboratórios de teste de penetração

A tabela a seguir contém uma lista de requisitos e diretrizes para um ambiente de teste de penetração típico.

Requisito ou Diretriz	Descrição
Rede fechada	Você precisa garantir acesso controlado para e do ambiente de laboratório e acesso restrito à Internet.
Ambiente de computação virtualizado	Permite fácil implantação e recuperação dos dispositivos sendo testados.
Ambiente realista	Se você estiver organizando um ambiente de teste, ele deverá corresponder ao ambiente real o mais próximo possível.
Monitorização de saúde	Quando algo falha, você precisa ser capaz de determinar por que aconteceu.
Recursos de hardware suficientes	Você precisa ter certeza de que a falta de recursos não é a causa de resultados falsos.
Múltiplos sistemas operacionais	Muitas vezes você deseja testar ou validar uma descoberta de outro sistema.É sempre bom testar de sistemas operacionais diferentes para ver se os resultados diferem.
Ferramentas duplicadas	Uma ótima maneira de validar um achado é executar o mesmo teste com uma ferramenta diferente para ver se os resultados são iguais.
Alvos de prática	Você precisa praticar usando suas ferramentas.Para isso, você precisa praticar em alvos conhecidos como vulneráveis.

Que ferramentas você deve usar em seu laboratório?

- Basicamente, as ferramentas que você usa nos testes de penetração dependem do tipo de teste que você está fazendo.
- Se estiver fazendo testes em um ambiente do cliente, provavelmente estará avaliando várias superfícies de ataque, como infraestrutura de rede, infraestrutura sem fio, servidores da Web, servidores de banco de dados, sistemas Windows ou sistemas Linux, por exemplo.
- As ferramentas baseadas em infraestrutura de rede podem incluir ferramentas para farejar ou manipular o tráfego, inundar dispositivos de rede e ignorar firewalls e IPSs.
- Para fins de teste sem fio, você pode usar ferramentas para quebrar criptografia sem fio, desautorizar dispositivos de rede e realizar ataques no caminho (também chamados de ataques homem-no-meio).
- Ao testar aplicativos e serviços da Web, você pode encontrar várias ferramentas automatizadas criadas especificamente para escanear e detectar vulnerabilidades da Web, bem como ferramentas de teste manuais, como proxies de interceptação.

Quais ferramentas você deve usar em seu laboratório?(Cont.)

- Algumas dessas mesmas ferramentas podem ser usadas para testar vulnerabilidades de banco de dados (como vulnerabilidades de injeção de SQL).
- Para testar as plataformas de servidor e cliente em um ambiente, você pode usar várias ferramentas de varredura automatizadas de vulnerabilidade para identificar coisas como software ultrapassado e configurações incorretas.
- Com muito desenvolvimento visando plataformas móveis, há uma necessidade crescente de testar esses aplicativos e os servidores que os suportam.
- Para esses testes, você precisa de outro conjunto de ferramentas específicas para testar aplicativos móveis e as APIs de back-end com as quais eles geralmente se comunicam.
- E não deve se esquecer de ferramentas de fuzzing, que normalmente são usadas para testar a robustez dos protocolos.

E se você quebrar alguma coisa?

- Ser capaz de recuperar o ambiente do laboratório é importante por diversas razões.
- Ao fazer testes de penetração, você vai quebrar as coisas, e às vezes eles não se recuperam por conta própria.
- Por exemplo, quando você está testando aplicativos da Web, alguns dos ataques que você envia inserem dados falsos em campos de formulário, e esses dados provavelmente acabarão no banco de dados, então seu banco de dados será preenchido com esses dados falsos.
- Obviamente, em um ambiente de produção, isso não é uma coisa boa.
- Os dados que estão sendo incluídos também podem ser de natureza maliciosa, como scripts e ataques de injeção.
- Isso pode causar corrupção do banco de dados também.
- Também é um problema em um ambiente de laboratório se você não tiver uma maneira fácil de recuperar o sistema.

E se você quebrar alguma coisa? (Cont.)

- Sem um método de recuperação rápida, você provavelmente estaria preso reconstruindo seu sistema em teste.
- Isso pode consumir tempo e, se você estiver fazendo isso por um cliente, isso pode afetar seu cronograma geral.
- Usar algum tipo de ambiente virtual é ideal, pois oferece snapshot e recursos de restauração para o estado do sistema.
- Às vezes isso não é possível, no entanto.
- Por exemplo, você pode estar testando um sistema que não pode ser virtualizado.
- Nesse caso, é necessário ter um backup completo do sistema ou do ambiente.
- Dessa forma, você pode estar operacional novamente e testar se algo quebrar, pois isso provavelmente acontecerá.
- Afinal, você está fazendo testes de penetração.

1.4 Resumo da Introdução a Hacking Ético e Testes de Penetração

O que eu aprendi neste módulo?

- O hacker ético é alguém que usa as mesmas ferramentas de hackers não éticos para encontrar vulnerabilidades na infra-estrutura de uma rede ou do sistema, mas relata suas descobertas para o provedor ou cliente para ajudar a tornar o sistema mais seguro.
- O objetivo dos testes de penetração é identificar possíveis caminhos de comprometimento antes dos atacantes maliciosos.
- É importante avaliar e testar a eficácia das técnicas defensivas usadas para proteger e defender redes e sistemas, e é aí que entram os testes de penetração.
- Alguns tipos de atores de ameaça são crime organizado, hacktivistas, agressores patrocinados pelo estado, e ameaças internas.
- É importante usar uma metodologia de testes de penetração para evitar a expansão do escopo e fornecer documentação de um procedimento especializado que tem sido usado com êxito por muitas organizações para testar suas infra-estruturas de rede e dados.
- Alguns tipos de testes de penetração são testes de infra-estrutura de rede, testes baseados em aplicativo e testes de penetração na nuvem.
- Algumas perspectivas a partir das quais os testes são realizados são testes de ambiente desconhecido, testes de ambiente conhecido e testes de ambiente parcialmente conhecidos.

O que eu aprendi neste módulo?(Cont.)

- Algumas metodologias de teste de penetração são MITRE ATT&CK, OWASP WSTG, NIST SP 800-115, OSSTMM, PTES e ISSAF.
- É importante ter um ambiente de laboratório adequado para testes de penetração e saber como usar diferentes tipos de ferramentas no processo de teste.
- É necessário testar ferramentas e técnicas em um ambiente de laboratório antes de executá-las contra uma rede do cliente para evitar danificar algo.
- Os requisitos para um laboratório de teste de penetração típico incluem rede fechada, ambiente de computação virtualizado, ambiente realista, monitoramento de saúde, recursos de hardware suficientes, múltiplos sistemas operacionais, ferramentas duplicadas e alvos de prática.
- Os tipos de ferramentas usadas nos testes de penetração dependem do tipo de teste que está sendo feito, como ferramentas baseadas em infraestrutura de rede, ferramentas de teste de aplicativos da Web, ferramentas de varredura de vulnerabilidades automatizadas e ferramentas de teste de aplicativos móveis.
- É importante ter um método de recuperação no caso de algo quebrar durante o teste.

Perguntas de Reflexão

- Por que as organizações precisam contratar hackers éticos?
- Por quê é importante seguir uma metodologia bem documentada ao fazer um teste de penetração?
- Qual é o valor de ter um laboratório de hacking ético, e quais são os requisitos para configurar um?